

Burpsuite Techniques

BY: PRANSHU TIWARI & OWASP PATNA

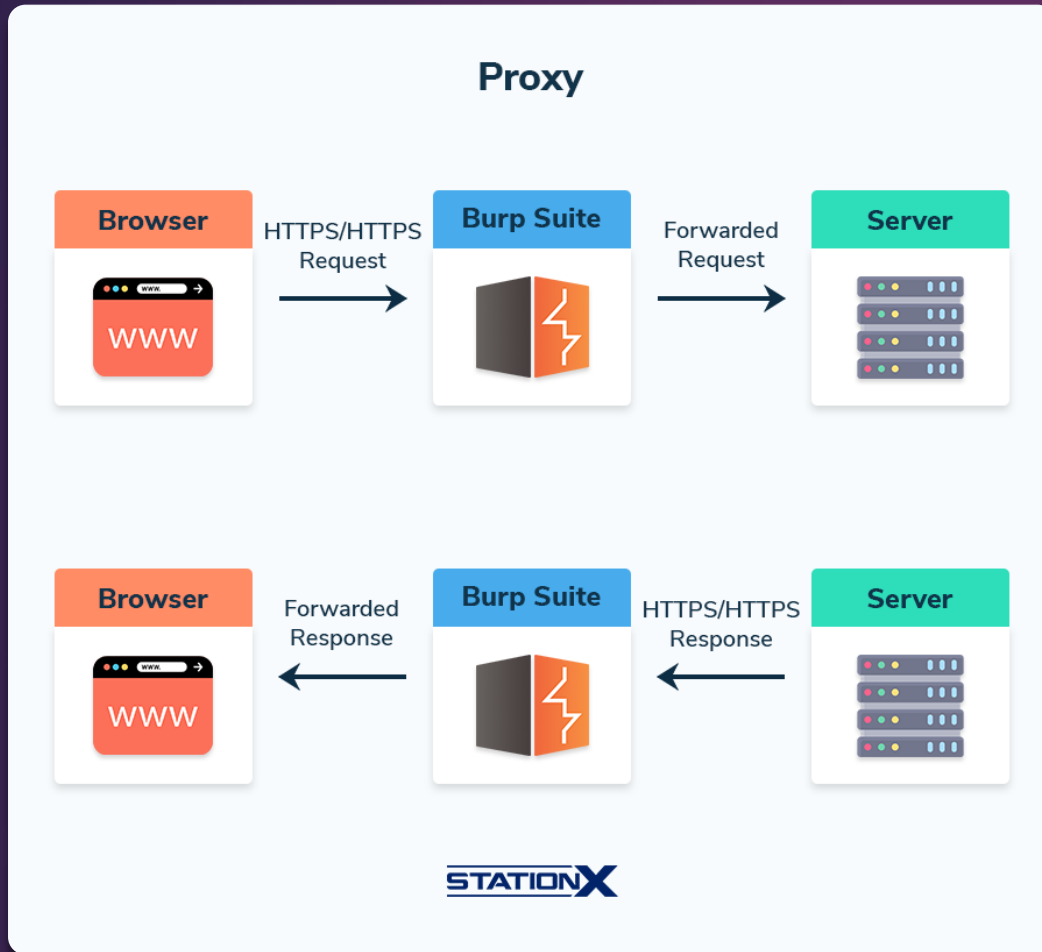
About Me ?

- ❖ **Experience:** Over 6+ years in cybersecurity with expertise in penetration testing for web, mobile, API, and Docker security.
- ❖ **Bug Bounty Hunter:** Reported critical vulnerabilities to major 100+ companies such as Google, Microsoft, Philips etc, contributing three CVEs.
- ❖ **Team Leadership:** Lead a team of 10+ penetration testers, showcasing strong communication and project management skills.
- ❖ **Certifications:** Holds certifications such as OSCP, PCI ASV, eWPT, and eWPTX, blending technical skills with strategic oversight.
- ❖ **Trainer:** Part time trainer for cyber security enthusiast who wanted to start career in this field or upskilling.

What is Burpsuite?

- ❖ **Intercepting Proxy:** Analyzes and modifies HTTP/S traffic in real time, facilitating in-depth testing.
- ❖ **Automated Scanning:** Includes Burp Scanner for automated detection of vulnerabilities across web applications.
- ❖ **Intruder Tool:** Supports payload injection and brute-force attacks to identify security weaknesses.
- ❖ **Manual Testing Features:** Offers tools like Repeater for manipulating requests and analyzing responses.
- ❖ **Customizability:** The Extender feature allows for custom plugins, enhancing functionality and tailoring testing scenarios.

How Burp Proxy Works



Intercept onForwardDrop

Request to http://127.0.0.1:8000

Time	Type	Direction	Host	Method	URL	Size
10:43:34 19 Oct 2024	HTTP	→ Request	127.0.0.1	GET	http://127.0.0.1:8000/	104
10:43:36 19 Oct 2024	HTTP	→ Request	localhost	GET	http://localhost:15612/	104

Request

PrettyRawHex

```
1 GET / HTTP/1.1
2 Host: 127.0.0.1:8000
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:131.0) Gecko/20100101 Firefox/131.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,image/svg+xml,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://127.0.0.1:8000/
8 Connection: keep-alive
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Dest: document
11 Sec-Fetch-Mode: navigate
```

Capture Localhost

Target Tab

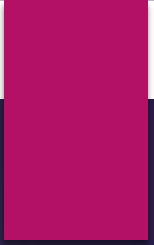
- ❖ **Target Overview:** Displays all identified URLs and parameters, providing a structured view of the application's attack surface.
- ❖ **Site Map:** Organizes the application structure, showing directories, files, and endpoints for easy navigation and analysis.
- ❖ **Scope Management:** Allows users to define and manage the scope of testing, ensuring that only relevant targets are included.
- ❖ **Active/Passive Scanning:** Facilitates both active and passive scanning of targets to identify vulnerabilities without disrupting normal operations.
- ❖ **Request History:** Maintains a log of all requests made during testing, enabling easy reference and analysis of interactions with the application.

Repeater Tab

- ❖ **Request Modifications:** Users can easily modify headers, cookies, and body content, allowing for granular control over each request to simulate various attack scenarios.
- ❖ **Response Analysis Tools:** Provides built-in tools for analyzing responses, including syntax highlighting and search functionality to quickly locate vulnerabilities or anomalies.
- ❖ **Repeat with Different Methods:** Allows users to quickly switch between HTTP methods (GET, POST, PUT, DELETE) to test the same endpoint under different conditions.
- ❖ **Customizable Environment:** Users can set specific environment variables for requests, enabling the testing of different application configurations without manual changes.
- ❖ **Support for Macros:** Enables the creation of macros for repetitive tasks, allowing users to automate common modifications or testing sequences for efficiency.

Sequencer Tab

- ❖ **Token Analysis:** The Sequencer analyzes the randomness and predictability of tokens, such as session identifiers or API keys, to assess their security.
- ❖ **Statistical Analysis:** It provides various statistical measures, including entropy calculations, to evaluate the strength of generated tokens against potential attacks.
- ❖ **Request Generation:** Users can configure and send requests to capture tokens for analysis, facilitating the examination of how tokens are generated and managed.
- ❖ **Sampling Options:** The Sequencer allows for the collection of multiple samples, enabling thorough analysis of token generation over time for more accurate results.
- ❖ **Visual Insights:** It offers visual representations of token patterns and distributions, helping pentesters easily identify weaknesses in token generation mechanisms.



Thank You